

Reporte Ejecutivo de Riesgos Tecnológicos

Destinatario: Directorio de la Clínica

Fecha: 5 de Septiembre de 2026

1. Resumen Ejecutivo

El presente informe detalla el estado actual de la postura de ciberseguridad y continuidad operativa de la clínica. Tras una evaluación exhaustiva de los activos tecnológicos, se identificaron vulnerabilidades críticas que exponen a la institución a interrupciones severas en la atención de pacientes, pérdidas financieras directas y sanciones legales por incumplimiento de la Ley 25.326 de Protección de los Datos Personales. La estrategia prioritaria exige la adopción inmediata de medidas de mitigación tecnológicas (Backups inmutables, MFA) y procedimentales (Control de accesos) para neutralizar los vectores de ataque más probables, garantizando la integridad de las historias clínicas y la facturación en tiempo real.

2. Inventario y Clasificación de Activos Críticos

A continuación se detallan los activos tecnológicos fundamentales afectados por los riesgos identificados, clasificados según su nivel de criticidad.

ID	Descripción del Activo	Tipo	Responsable	Clasificación	Criticidad
A01	Base de datos de Historias Clínicas	Información	Jefatura Médica	Confidencial	Alta
A02	Sistema de Facturación	Software	Ger. Financiera	Restringida	Alta
A03	Personal del área de Facturación	Humano	Ger. Financiera	Interna	Media
A04	Sistema de Gestión Hospitalaria (HIS)	Software	Gerencia TI	Confidencial	Alta
A05	Enlace principal a Internet (ISP)	Red	Gerencia TI	Pública	Alta
A06	Servidores físicos del Data Center	Hardware	Gerencia TI	Restringida	Alta

3. Top 5 Riesgos por Nivel

Los siguientes riesgos representan la mayor amenaza para la organización, calculados en base a su impacto (1-5) y probabilidad (1-5).

#	Riesgo Identificado	Impacto	Probabilidad	Puntaje
1	Infección por Ransomware en bases de datos.	5	4	20 (Crítico)
2	Fraude financiero por Phishing a facturación.	4	4	16 (Crítico)
3	Exposición de datos por exceso de privilegios.	4	3	12 (Alto)
4	Interrupción de Obras Sociales por corte de ISP.	4	3	12 (Alto)
5	Apagón del Data Center por falla eléctrica.	5	2	10 (Alto)

4. Estado de los Planes de Acción (Riesgos Altos/Críticos)

Se han diagramado tres planes de mitigación inmediatos para contener las amenazas más urgentes.

- **Plan 1: Arquitectura de Backups Inmutables y EDR (Ransomware)**

- **Estado:** Planificado.
- **Vencimiento:** 30/10/2026.
- **Presupuesto:** \$5,500 USD.
- **Responsable:** Gerencia de TI.

- **Plan 2: MFA Obligatorio y Concientización (Phishing)**

- **Estado:** En curso (Evaluación de proveedores).
- **Vencimiento:** 15/10/2026.
- **Presupuesto:** \$1,200 USD.
- **Responsable:** Gerencia Financiera.

- **Plan 3: Transición a RBAC en Recepción (Exposición de Datos)**

- **Estado:** Planificado.
- **Vencimiento:** 15/11/2026.
- **Presupuesto:** \$0 (Costos operativos internos).
- **Responsable:** Jefatura de Recepción.

5. Recomendaciones Prioritarias

Para asegurar la viabilidad operativa de la clínica en el corto plazo, se emiten las siguientes recomendaciones vinculantes al Directorio:

1. **Aprobación Presupuestaria Inmediata:** Liberar los fondos estimados (\$6,700 USD) para ejecutar los Planes 1 y 2, cerrando las brechas críticas que actualmente permiten la ejecución de secuestros de datos y estafas financieras.

2. **Adopción de Políticas Zero Trust:** Eliminar definitivamente el uso de cuentas genéricas compartidas en los sistemas de gestión hospitalaria (HIS), exigiendo responsabilidad individual en el manejo de datos de pacientes para cumplir con normativas legales.
3. **Redundancia de Infraestructura Crítica:** Iniciar la contratación de un Proveedor de Servicios de Internet (ISP) secundario para garantizar la facturación y validación ininterrumpida con las Obras Sociales.